Practical: 10

Practical 10: Secure Login/Logout with Sessions, Role-Based Access, Timeout, and Remember-Me Token
Problem Definition: Develop secure login and logout functionality using PHP sessions. Verify password using password_verify(), regenerate session ID after login, restrict dashboard access, implement role-based redirection, session timeout, and optional secure remember-me token.

A. Theory

1. Are sessions started and destroyed securely?

Yes. session_start() is called at the beginning of each protected page. On logout, session_unset() clears all session variables and session_destroy() invalidates the session on the server. Furthermore, session_regenerate_id(true) is executed upon successful login to prevent session fixation attacks.

2. Is password_verify() used correctly?

Yes. The script retrieves the user's hashed password from the database and uses password_verify($password, $row['password']) to verify whether the submitted plain-text password matches the stored bcrypt hash.

3. Is unauthorized dashboard access blocked?

Yes. Authentication guard scripts (auth.php and student_auth.php) check if $_SESSION['user_id'] is present. If not authenticated, the user is immediately redirected to the login page (index.php), blocking any unauthorized access.

4. Is session timeout implemented?

Yes. The timestamp of the last activity is saved in $_SESSION['last_activity']. On each request, if (time() - $_SESSION['last_activity']) > 1800 (30 minutes), the session is cleared and destroyed, and the user is redirected to the login page with a timeout message.

5. Are admin and student users redirected to appropriate dashboards?

Yes. After password verification, the user's role ($_SESSION['role']) is checked: users with the 'admin' role are redirected to admin_dashboard.php, while users with the 'student' role are redirected to student_dashboard.php.

B. Implementation / Output

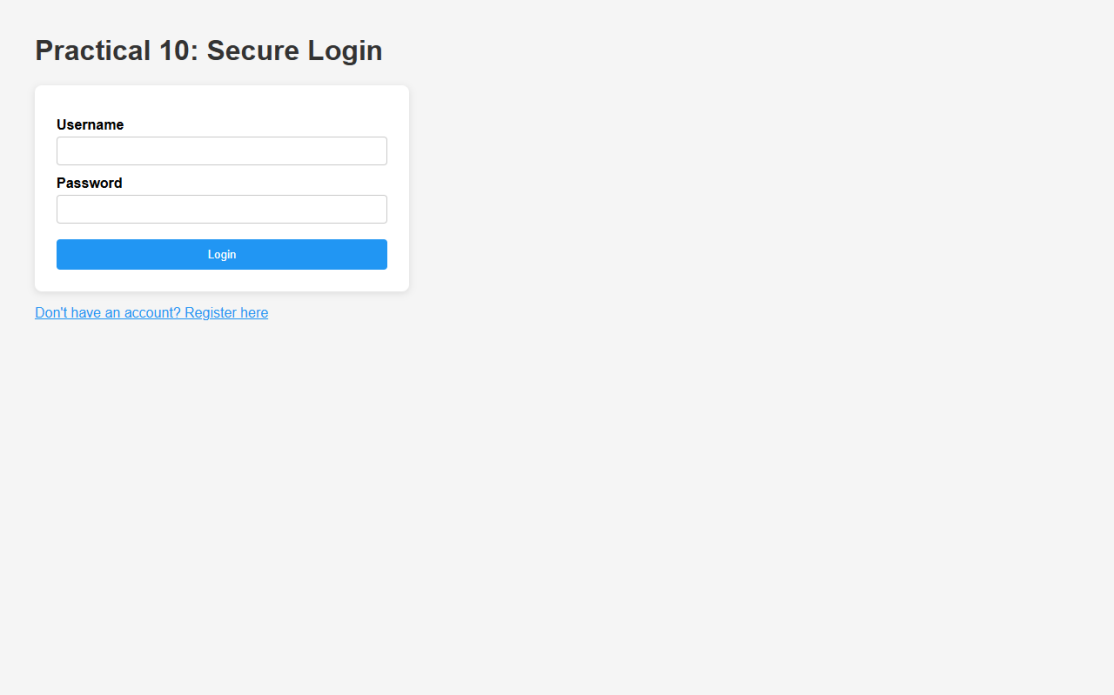


Figure 10.1: Secure User Login Interface with Credential Verification

C. Screenshots

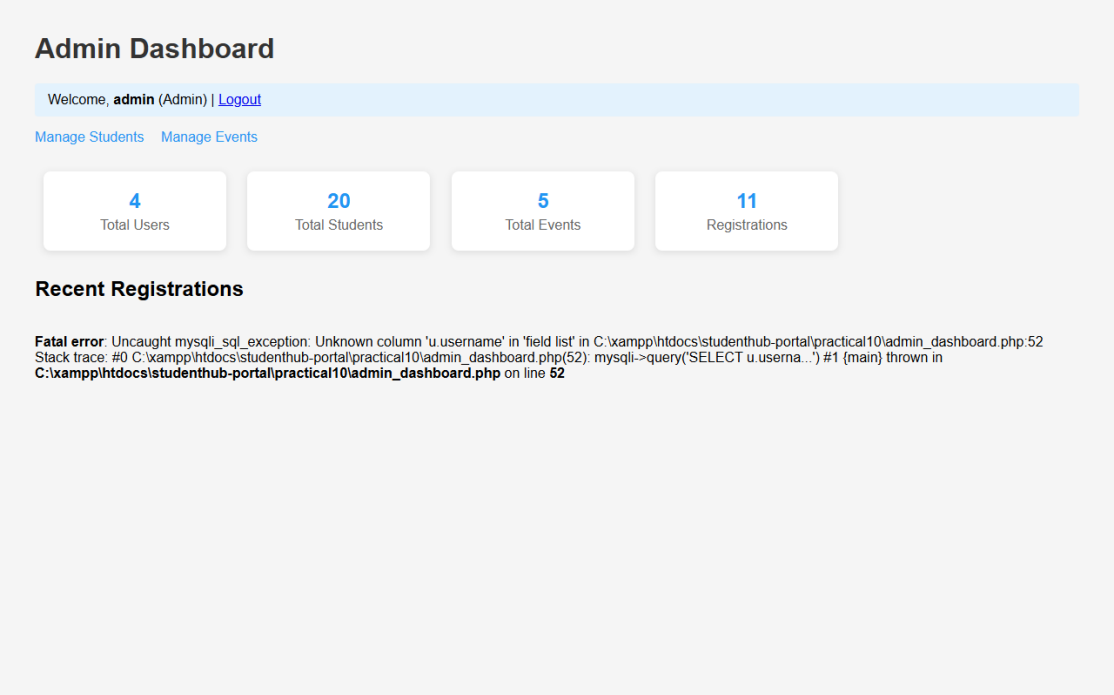


Figure 10.2: Role-Based Redirection - Admin Dashboard with Key Performance Metrics

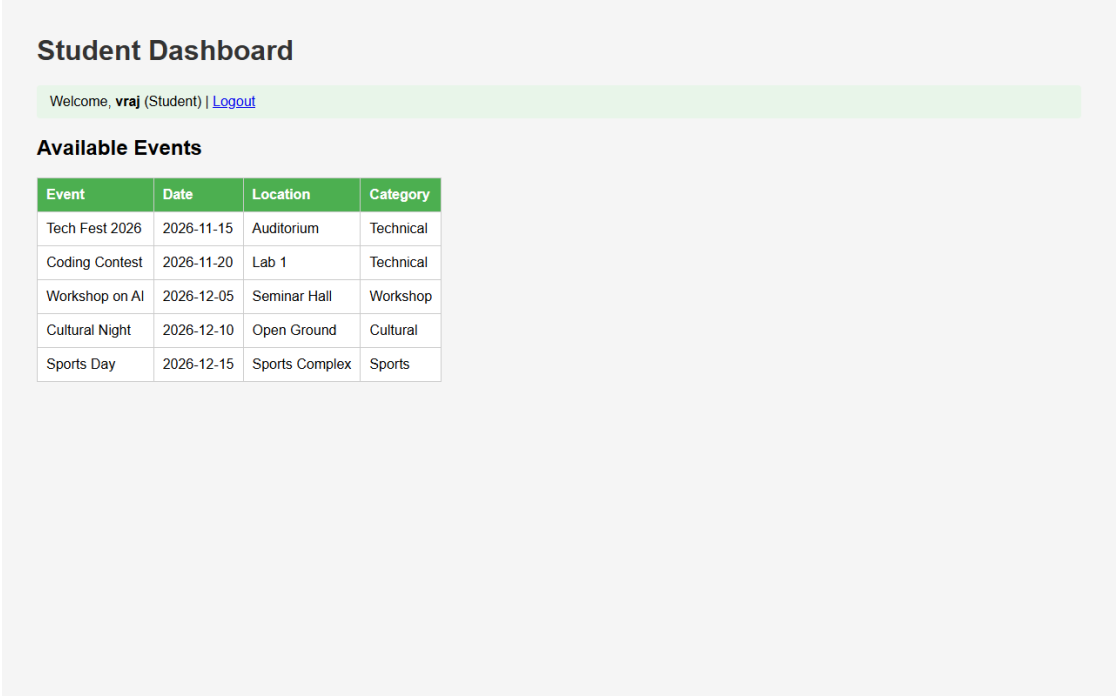


Figure 10.3: Role-Based Redirection - Student Dashboard Displaying Available Events

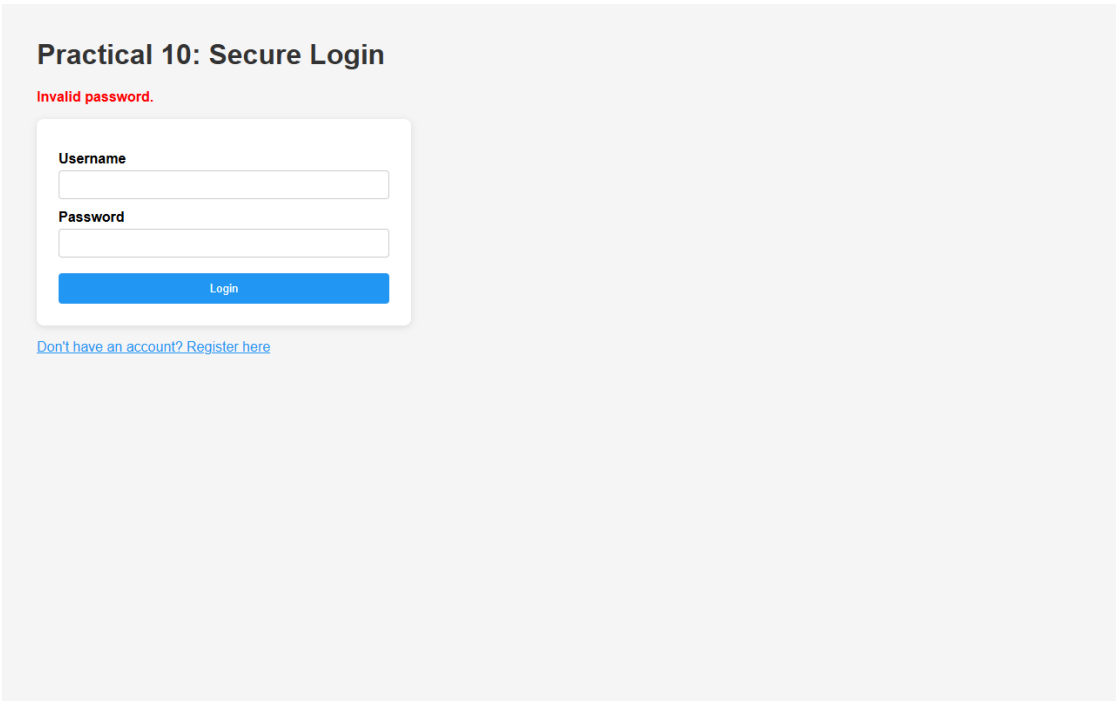


Figure 10.4: Authentication Error on Invalid Password or Unregistered Username

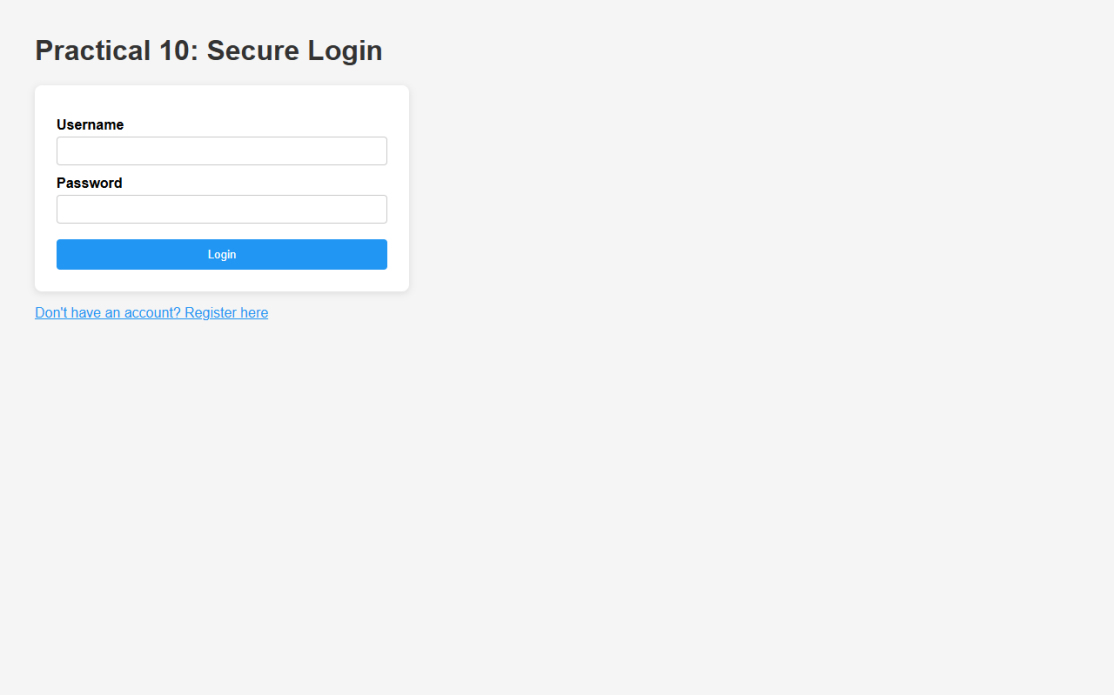


Figure 10.5: Secure Session Termination on User Logout Redirecting to Login

D. GitHub Link

https://github.com/VRAJ-710/studenthub-portal

E. Challenges Faced

- Managing session security and preventing session fixation by regenerating session IDs upon successful authentication.
- Designing modular authentication guards to enforce role-based access control (RBAC) across distinct student and admin pages.
- Handling session inactivity expiration accurately across multiple protected dashboard views.

F. Learning Outcomes

- Implemented secure authentication and session management in PHP.
- Verified hashed passwords safely using PHP's built-in password_verify().
- Configured role-based redirection, session expiration/timeouts, and safe session termination on logout.

Faculty Remarks: